



**ZAP** by  
Checkmarx

# ZAP by Checkmarx Scanning Report

Sites: <https://testasp.vulnweb.com> <http://testasp.vulnweb.com>

Generated on Thu, 18 Jun 2026 15:31:50

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

## Summary of Alerts

| Risk Level    | Number of Alerts |
|---------------|------------------|
| High          | 6                |
| Medium        | 4                |
| Low           | 7                |
| Informational | 4                |

## Insights

| Level | Reason        | Site                                                                | Description                                             | Statistic |
|-------|---------------|---------------------------------------------------------------------|---------------------------------------------------------|-----------|
| Low   | Warning       |                                                                     | ZAP errors logged - see the zap. log file for details   | 3         |
| Low   | Warning       |                                                                     | ZAP warnings logged - see the zap. log file for details | 19        |
| Low   | Exceeded High | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a> | Percentage of slow responses                            | 100 %     |
| Info  | Informational |                                                                     | Percentage of network failures                          | 1 %       |
| Info  | Informational | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a> | Percentage of responses with status code 2xx            | 39 %      |
| Info  | Informational | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a> | Percentage of responses with status code 3xx            | 12 %      |
| Info  |               |                                                                     | Percentage of responses                                 | 7 %       |

|      |               |                             |                                                                  |       |
|------|---------------|-----------------------------|------------------------------------------------------------------|-------|
|      | Exceeded Low  | http://testasp.vulnweb.com  | with status code 4xx                                             |       |
| Info | Exceeded Low  | http://testasp.vulnweb.com  | Percentage of responses with status code 5xx                     | 41 %  |
| Info | Informational | http://testasp.vulnweb.com  | Percentage of endpoints with content type application/javascript | 5 %   |
| Info | Informational | http://testasp.vulnweb.com  | Percentage of endpoints with content type image/gif              | 10 %  |
| Info | Informational | http://testasp.vulnweb.com  | Percentage of endpoints with content type text/css               | 5 %   |
| Info | Informational | http://testasp.vulnweb.com  | Percentage of endpoints with content type text/html              | 73 %  |
| Info | Informational | http://testasp.vulnweb.com  | Percentage of endpoints with content type text/plain             | 5 %   |
| Info | Informational | http://testasp.vulnweb.com  | Percentage of endpoints with method GET                          | 84 %  |
| Info | Informational | http://testasp.vulnweb.com  | Percentage of endpoints with method POST                         | 15 %  |
| Info | Informational | http://testasp.vulnweb.com  | Count of total endpoints                                         | 19    |
| Info | Informational | https://testasp.vulnweb.com | Percentage of endpoints with                                     | 100 % |

|      |               |                             |                          |   |
|------|---------------|-----------------------------|--------------------------|---|
|      |               |                             | method<br>POST           |   |
| Info | Informational | https://testasp.vulnweb.com | Count of total endpoints | 1 |

## Alerts

| Name                                                                                      | Risk Level    | Number of Instances |
|-------------------------------------------------------------------------------------------|---------------|---------------------|
| <a href="#">Cross Site Scripting (DOM Based)</a>                                          | High          | 2                   |
| <a href="#">Cross Site Scripting (Reflected)</a>                                          | High          | 1                   |
| <a href="#">External Redirect</a>                                                         | High          | 2                   |
| <a href="#">Path Traversal</a>                                                            | High          | 2                   |
| <a href="#">SQL Injection</a>                                                             | High          | 4                   |
| <a href="#">SQL Injection - MsSQL (Time Based)</a>                                        | High          | 3                   |
| <a href="#">Absence of Anti-CSRF Tokens</a>                                               | Medium        | 3                   |
| <a href="#">Content Security Policy (CSP) Header Not Set</a>                              | Medium        | Systemic            |
| <a href="#">HTTP Only Site</a>                                                            | Medium        | 1                   |
| <a href="#">Missing Anti-clickjacking Header</a>                                          | Medium        | Systemic            |
| <a href="#">Application Error Disclosure</a>                                              | Low           | 3                   |
| <a href="#">Cookie No HttpOnly Flag</a>                                                   | Low           | 1                   |
| <a href="#">Cookie without SameSite Attribute</a>                                         | Low           | 1                   |
| <a href="#">Information Disclosure - Debug Error Messages</a>                             | Low           | 3                   |
| <a href="#">Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)</a> | Low           | Systemic            |
| <a href="#">Server Leaks Version Information via "Server" HTTP Response Header Field</a>  | Low           | Systemic            |
| <a href="#">X-Content-Type-Options Header Missing</a>                                     | Low           | Systemic            |
| <a href="#">GET for POST</a>                                                              | Informational | 1                   |
| <a href="#">Information Disclosure - Suspicious Comments</a>                              | Informational | 1                   |
| <a href="#">Session Management Response Identified</a>                                    | Informational | 1                   |
| <a href="#">User Agent Fuzzer</a>                                                         | Informational | Systemic            |

## Alert Detail

| High | Cross Site Scripting (DOM Based)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|      | <p>Cross-site Scripting (XSS) is an attack technique that involves echoing attacker-supplied code into a user's browser instance. A browser instance can be a standard web browser client, or a browser object embedded in a software product such as the browser within WinAmp, an RSS reader, or an email client. The code itself is usually written in HTML /JavaScript, but may also extend to VBScript, ActiveX, Java, Flash, or any other browser-supported technology.</p> <p>When an attacker gets a user's browser to execute his/her code, the code will run within the security context (or zone) of the hosting web site. With this level of privilege, the code has the ability to read, modify and transmit any sensitive data accessible by the browser. A Cross-site Scripted user could have his/her account hijacked (cookie theft), their browser redirected to another location, or possibly shown fraudulent content delivered by the web site they are visiting. Cross-site Scripting attacks essentially compromise the trust</p> |

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description | <p>relationship between a user and the web site. Applications utilizing browser object instances which load content from the file system may execute code under the local machine zone allowing for system compromise.</p> <p>There are three types of Cross-site Scripting attacks: non-persistent, persistent and DOM-based.</p> <p>Non-persistent attacks and DOM-based attacks require a user to either visit a specially crafted link laced with malicious code, or visit a malicious web page containing a web form, which when posted to the vulnerable site, will mount the attack. Using a malicious form will oftentimes take place when the vulnerable resource only accepts HTTP POST requests. In such a case, the form can be submitted automatically, without the victim's knowledge (e.g. by using JavaScript). Upon clicking on the malicious link or submitting the malicious form, the XSS payload will get echoed back and will get interpreted by the user's browser and execute. Another technique to send almost arbitrary requests (GET and POST) is by using an embedded client, such as Adobe Flash.</p> <p>Persistent attacks occur when the malicious code is submitted to a web site where it's stored for a period of time. Examples of an attacker's favorite targets often include message board posts, web mail messages, and web chat software. The unsuspecting user is not required to interact with any additional site/link (e.g. an attacker site or a malicious link sent via email), just simply view the web page containing the code.</p> |
| URL         | <a href="http://testasp.vulnweb.com/Search.asp?name=abc#&lt;img src='random.gif' onerror=alert(5397)&gt;">http://testasp.vulnweb.com/Search.asp?name=abc#&lt;img src="random.gif" onerror=alert(5397)&gt;</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Node Name   | http://testasp.vulnweb.com/Search.asp                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Attack      | ?name=abc#                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Other Info  | <p>The following steps were done to trigger the DOM XSS: With &lt;PAYLOAD_0&gt; as: ? name=abc#&lt;img src="random.gif" onerror=alert(5397)&gt; Access: http://testasp.vulnweb.com/Search.asp&lt;PAYLOAD_0&gt; Write to /html/body/table/tbody/tr[3]/td/form/div/input[1] the value: &lt;PAYLOAD_0&gt; Click element: /html/body/table/tbody/tr[3]/td/form/div/input[1] Access: http://testasp.vulnweb.com/Search.asp&lt;PAYLOAD_0&gt; Write to /html/body/table/tbody/tr[3]/td/form/div/input[2] the value: &lt;PAYLOAD_0&gt; Click element: /html/body/table/tbody/tr[3]/td/form/div/input[2] Access: http://testasp.vulnweb.com/Search.asp&lt;PAYLOAD_0&gt; Click element: /html/body/table[1]/tbody[1]/tr[2]/td/div Access: http://testasp.vulnweb.com/Search.asp&lt;PAYLOAD_0&gt;</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| URL         | <a href="http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP?name=abc#&lt;img src='random.gif' onerror=alert(5397)&gt;">http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP?name=abc#&lt;img src="random.gif" onerror=alert(5397)&gt;</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Node Name   | http://testasp.vulnweb.com/Search.asp (tfSearch)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Attack      | ?name=abc#                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Other Info  | <p>The following steps were done to trigger the DOM XSS: With &lt;PAYLOAD_0&gt; as: ? name=abc#&lt;img src="random.gif" onerror=alert(5397)&gt; Access: http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP&lt;PAYLOAD_0&gt; Write to /html/body/table[1]/tbody/tr[3]/td/form/div/input[1] the value: &lt;PAYLOAD_0&gt; Click element: /html/body/table[1]/tbody/tr[3]/td/form/div/input[1] Access: http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP&lt;PAYLOAD_0&gt; Write to /html/body/table[1]/tbody/tr[3]/td/form/div/input[2] the value: &lt;PAYLOAD_0&gt; Click element: /html/body/table[1]/tbody/tr[3]/td/form/div/input[2] Access: http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP&lt;PAYLOAD_0&gt; Click element: /html/body/table[1]/tbody[1]/tr[2]/td/div Access: http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP&lt;PAYLOAD_0&gt;</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Instances   | 2                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|             | <p>Phase: Architecture and Design</p> <p>Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Solution  | <p>Examples of libraries and frameworks that make it easier to generate properly encoded output include Microsoft's Anti-XSS library, the OWASP ESAPI Encoding module, and Apache Wicket.</p> <p>Phases: Implementation; Architecture and Design</p> <p>Understand the context in which your data will be used and the encoding that will be expected. This is especially important when transmitting data between different components, or when generating outputs that can contain multiple encodings at the same time, such as web pages or multi-part mail messages. Study all expected communication protocols and data representations to determine the required encoding strategies.</p> <p>For any data that will be output to another web page, especially any data that was received from external inputs, use the appropriate encoding on all non-alphanumeric characters.</p> <p>Consult the XSS Prevention Cheat Sheet for more details on the types of encoding and escaping that are needed.</p> <p>Phase: Architecture and Design</p> <p>For any security checks that are performed on the client side, ensure that these checks are duplicated on the server side, in order to avoid CWE-602. Attackers can bypass the client-side checks by modifying values after the checks have been performed, or by changing the client to remove the client-side checks entirely. Then, these modified values would be submitted to the server.</p> <p>If available, use structured mechanisms that automatically enforce the separation between data and code. These mechanisms may be able to provide the relevant quoting, encoding, and validation automatically, instead of relying on the developer to provide this capability at every point where output is generated.</p> <p>Phase: Implementation</p> <p>For every web page that is generated, use and specify a character encoding such as ISO-8859-1 or UTF-8. When an encoding is not specified, the web browser may choose a different encoding by guessing which encoding is actually being used by the web page. This can cause the web browser to treat certain sequences as special, opening up the client to subtle XSS attacks. See CWE-116 for more mitigations related to encoding/escaping.</p> <p>To help mitigate XSS attacks against the user's session cookie, set the session cookie to be HttpOnly. In browsers that support the HttpOnly feature (such as more recent versions of Internet Explorer and Firefox), this attribute can prevent the user's session cookie from being accessible to malicious client-side scripts that use document.cookie. This is not a complete solution, since HttpOnly is not supported by all browsers. More importantly, XMLHttpRequest and other powerful browser technologies provide read access to HTTP headers, including the Set-Cookie header in which the HttpOnly flag is set.</p> <p>Assume all input is malicious. Use an "accept known good" input validation strategy, i.e., use an allow list of acceptable inputs that strictly conform to specifications. Reject any input that does not strictly conform to specifications, or transform it into something that does. Do not rely exclusively on looking for malicious or malformed inputs (i.e., do not rely on a deny list). However, deny lists can be useful for detecting potential attacks or determining which inputs are so malformed that they should be rejected outright.</p> <p>When performing input validation, consider all potentially relevant properties, including length, type of input, the full range of acceptable values, missing or extra inputs, syntax, consistency across related fields, and conformance to business rules. As an example of business rule logic, "boat" may be syntactically valid because it only contains alphanumeric characters, but it is not valid if you are expecting colors such as "red" or "blue."</p> <p>Ensure that you perform input validation at well-defined interfaces within the application. This will help protect the application even if a component is reused or moved elsewhere.</p> |
| Reference | <a href="https://owasp.org/www-community/attacks/xss/">https://owasp.org/www-community/attacks/xss/</a><br><a href="https://cwe.mitre.org/data/definitions/79.html">https://cwe.mitre.org/data/definitions/79.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| CWE Id    | <a href="#">79</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| WASC Id     | 8                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Plugin Id   | <a href="#">40026</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| High        | Cross Site Scripting (Reflected)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Description | <p>Cross-site Scripting (XSS) is an attack technique that involves echoing attacker-supplied code into a user's browser instance. A browser instance can be a standard web browser client, or a browser object embedded in a software product such as the browser within WinAmp, an RSS reader, or an email client. The code itself is usually written in HTML /JavaScript, but may also extend to VBScript, ActiveX, Java, Flash, or any other browser-supported technology.</p> <p>When an attacker gets a user's browser to execute his/her code, the code will run within the security context (or zone) of the hosting web site. With this level of privilege, the code has the ability to read, modify and transmit any sensitive data accessible by the browser. A Cross-site Scripted user could have his/her account hijacked (cookie theft), their browser redirected to another location, or possibly shown fraudulent content delivered by the web site they are visiting. Cross-site Scripting attacks essentially compromise the trust relationship between a user and the web site. Applications utilizing browser object instances which load content from the file system may execute code under the local machine zone allowing for system compromise.</p> <p>There are three types of Cross-site Scripting attacks: non-persistent, persistent and DOM-based.</p> <p>Non-persistent attacks and DOM-based attacks require a user to either visit a specially crafted link laced with malicious code, or visit a malicious web page containing a web form, which when posted to the vulnerable site, will mount the attack. Using a malicious form will oftentimes take place when the vulnerable resource only accepts HTTP POST requests. In such a case, the form can be submitted automatically, without the victim's knowledge (e.g. by using JavaScript). Upon clicking on the malicious link or submitting the malicious form, the XSS payload will get echoed back and will get interpreted by the user's browser and execute. Another technique to send almost arbitrary requests (GET and POST) is by using an embedded client, such as Adobe Flash.</p> <p>Persistent attacks occur when the malicious code is submitted to a web site where it's stored for a period of time. Examples of an attacker's favorite targets often include message board posts, web mail messages, and web chat software. The unsuspecting user is not required to interact with any additional site/link (e.g. an attacker site or a malicious link sent via email), just simply view the web page containing the code.</p> |
| URL         | <a href="http://testasp.vulnweb.com/showthread.asp?id=3">http://testasp.vulnweb.com/showthread.asp?id=3</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Node Name   | http://testasp.vulnweb.com/showthread.asp (id)(tfSubject,tfText)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Method      | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Attack      | </div><script>alert(1);</script><div>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Evidence    | </div><script>alert(1);</script><div>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Other Info  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Instances   | 1                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|             | <p>Phase: Architecture and Design</p> <p>Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid.</p> <p>Examples of libraries and frameworks that make it easier to generate properly encoded output include Microsoft's Anti-XSS library, the OWASP ESAPI Encoding module, and Apache Wicket.</p> <p>Phases: Implementation; Architecture and Design</p> <p>Understand the context in which your data will be used and the encoding that will be expected. This is especially important when transmitting data between different</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |

|          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Solution | <p>components, or when generating outputs that can contain multiple encodings at the same time, such as web pages or multi-part mail messages. Study all expected communication protocols and data representations to determine the required encoding strategies.</p> <p>For any data that will be output to another web page, especially any data that was received from external inputs, use the appropriate encoding on all non-alphanumeric characters.</p> <p>Consult the XSS Prevention Cheat Sheet for more details on the types of encoding and escaping that are needed.</p> <p>Phase: Architecture and Design</p> <p>For any security checks that are performed on the client side, ensure that these checks are duplicated on the server side, in order to avoid CWE-602. Attackers can bypass the client-side checks by modifying values after the checks have been performed, or by changing the client to remove the client-side checks entirely. Then, these modified values would be submitted to the server.</p> <p>If available, use structured mechanisms that automatically enforce the separation between data and code. These mechanisms may be able to provide the relevant quoting, encoding, and validation automatically, instead of relying on the developer to provide this capability at every point where output is generated.</p> <p>Phase: Implementation</p> <p>For every web page that is generated, use and specify a character encoding such as ISO-8859-1 or UTF-8. When an encoding is not specified, the web browser may choose a different encoding by guessing which encoding is actually being used by the web page. This can cause the web browser to treat certain sequences as special, opening up the client to subtle XSS attacks. See CWE-116 for more mitigations related to encoding/escaping.</p> <p>To help mitigate XSS attacks against the user's session cookie, set the session cookie to be HttpOnly. In browsers that support the HttpOnly feature (such as more recent versions of Internet Explorer and Firefox), this attribute can prevent the user's session cookie from being accessible to malicious client-side scripts that use document.cookie. This is not a complete solution, since HttpOnly is not supported by all browsers. More importantly, XMLHttpRequest and other powerful browser technologies provide read access to HTTP headers, including the Set-Cookie header in which the HttpOnly flag is set.</p> <p>Assume all input is malicious. Use an "accept known good" input validation strategy, i.e., use an allow list of acceptable inputs that strictly conform to specifications. Reject any input that does not strictly conform to specifications, or transform it into something that does. Do not rely exclusively on looking for malicious or malformed inputs (i.e., do not rely on a deny list). However, deny lists can be useful for detecting potential attacks or determining which inputs are so malformed that they should be rejected outright.</p> <p>When performing input validation, consider all potentially relevant properties, including length, type of input, the full range of acceptable values, missing or extra inputs, syntax, consistency across related fields, and conformance to business rules. As an example of business rule logic, "boat" may be syntactically valid because it only contains alphanumeric characters, but it is not valid if you are expecting colors such as "red" or "blue."</p> <p>Ensure that you perform input validation at well-defined interfaces within the application. This will help protect the application even if a component is reused or moved elsewhere.</p> |
|          | <p>Reference</p> <p><a href="https://owasp.org/www-community/attacks/xss/">https://owasp.org/www-community/attacks/xss/</a><br/> <a href="https://cwe.mitre.org/data/definitions/79.html">https://cwe.mitre.org/data/definitions/79.html</a></p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|          | <p>CWE Id</p> <p><a href="#">79</a></p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|          | <p>WASC Id</p> <p>8</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|          | <p>Plugin Id</p> <p><a href="#">40012</a></p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| High     | External Redirect                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|          | <p>URL redirectors represent common functionality employed by web sites to forward an incoming request to an alternate resource. This can be done for a variety of reasons and is often done to allow resources to be moved within the directory structure and to avoid</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description | breaking functionality for users that request the resource at its previous location. URL redirectors may also be used to implement load balancing, leveraging abbreviated URLs or recording outgoing links. It is this last implementation which is often used in phishing attacks as described in the example below. URL redirectors do not necessarily represent a direct security vulnerability but can be abused by attackers trying to social engineer victims into believing that they are navigating to a site other than the true destination.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| URL         | <a href="http://testasp.vulnweb.com/Logout.asp?RetURL=https%3A%2F%2F1315667678935467041.owasp.org">http://testasp.vulnweb.com/Logout.asp?RetURL=https%3A%2F%2F1315667678935467041.owasp.org</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Node Name   | http://testasp.vulnweb.com/Logout.asp (RetURL)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Attack      | https://1315667678935467041.owasp.org                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Evidence    | https://1315667678935467041.owasp.org                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Other Info  | The response contains a redirect in its Location header which allows an external Url to be set.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| URL         | <a href="http://testasp.vulnweb.com/Login.asp?RetURL=https%3A%2F%2F1315667678935467041.owasp.org">http://testasp.vulnweb.com/Login.asp?RetURL=https%3A%2F%2F1315667678935467041.owasp.org</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Node Name   | http://testasp.vulnweb.com/Login.asp (RetURL)(tfUName,tfUPass)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Method      | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Attack      | https://1315667678935467041.owasp.org                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Evidence    | https://1315667678935467041.owasp.org                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Other Info  | The response contains a redirect in its Location header which allows an external Url to be set.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Instances   | 2                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Solution    | <p>Assume all input is malicious. Use an "accept known good" input validation strategy, i.e., use an allow list of acceptable inputs that strictly conform to specifications. Reject any input that does not strictly conform to specifications, or transform it into something that does. Do not rely exclusively on looking for malicious or malformed inputs (i.e., do not rely on a deny list). However, deny lists can be useful for detecting potential attacks or determining which inputs are so malformed that they should be rejected outright.</p> <p>When performing input validation, consider all potentially relevant properties, including length, type of input, the full range of acceptable values, missing or extra inputs, syntax, consistency across related fields, and conformance to business rules. As an example of business rule logic, "boat" may be syntactically valid because it only contains alphanumeric characters, but it is not valid if you are expecting colors such as "red" or "blue."</p> <p>Use an allow list of approved URLs or domains to be used for redirection.</p> <p>Use an intermediate disclaimer page that provides the user with a clear warning that they are leaving your site. Implement a long timeout before the redirect occurs, or force the user to click on the link. Be careful to avoid XSS problems when generating the disclaimer page.</p> <p>When the set of acceptable objects, such as filenames or URLs, is limited or known, create a mapping from a set of fixed input values (such as numeric IDs) to the actual filenames or URLs, and reject all other inputs.</p> <p>For example, ID 1 could map to "/login.asp" and ID 2 could map to "https://www.example.com/". Features such as the ESAPI AccessReferenceMap provide this capability.</p> <p>Understand all the potential areas where untrusted inputs can enter your software: parameters or arguments, cookies, anything read from the network, environment variables, reverse DNS lookups, query results, request headers, URL components, e-mail, files, databases, and any external systems that provide data to the application. Remember that such inputs may be obtained indirectly through API calls.</p> <p>Many open redirect problems occur because the programmer assumed that certain inputs could not be modified, such as cookies and hidden form fields.</p> |



|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Solution    | <p>Assume all input is malicious. Use an "accept known good" input validation strategy, i.e., use an allow list of acceptable inputs that strictly conform to specifications. Reject any input that does not strictly conform to specifications, or transform it into something that does. Do not rely exclusively on looking for malicious or malformed inputs (i.e., do not rely on a deny list). However, deny lists can be useful for detecting potential attacks or determining which inputs are so malformed that they should be rejected outright.</p> <p>When performing input validation, consider all potentially relevant properties, including length, type of input, the full range of acceptable values, missing or extra inputs, syntax, consistency across related fields, and conformance to business rules. As an example of business rule logic, "boat" may be syntactically valid because it only contains alphanumeric characters, but it is not valid if you are expecting colors such as "red" or "blue."</p> <p>For filenames, use stringent allow lists that limit the character set to be used. If feasible, only allow a single "." character in the filename to avoid weaknesses, and exclude directory separators such as "/". Use an allow list of allowable file extensions.</p> <p>Warning: if you attempt to cleanse your data, then do so that the end result is not in the form that can be dangerous. A sanitizing mechanism can remove characters such as '.' and ';' which may be required for some exploits. An attacker can try to fool the sanitizing mechanism into "cleaning" data into a dangerous form. Suppose the attacker injects a '.' inside a filename (e.g. "sensi.tiveFile") and the sanitizing mechanism removes the character resulting in the valid filename, "sensitiveFile". If the input data are now assumed to be safe, then the file may be compromised.</p> |
|             | <p>Inputs should be decoded and canonicalized to the application's current internal representation before being validated. Make sure that your application does not decode the same input twice. Such errors could be used to bypass allow list schemes by introducing dangerous inputs after they have been checked.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|             | <p>Use a built-in path canonicalization function (such as <code>realpath()</code> in C) that produces the canonical version of the pathname, which effectively removes "." sequences and symbolic links.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|             | <p>Run your code using the lowest privileges that are required to accomplish the necessary tasks. If possible, create isolated accounts with limited privileges that are only used for a single task. That way, a successful attack will not immediately give the attacker access to the rest of the software or its environment. For example, database applications rarely need to run as the database administrator, especially in day-to-day operations.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|             | <p>When the set of acceptable objects, such as filenames or URLs, is limited or known, create a mapping from a set of fixed input values (such as numeric IDs) to the actual filenames or URLs, and reject all other inputs.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|             | <p>Run your code in a "jail" or similar sandbox environment that enforces strict boundaries between the process and the operating system. This may effectively restrict which files can be accessed in a particular directory or which commands can be executed by your software.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|             | <p>OS-level examples include the Unix chroot jail, AppArmor, and SELinux. In general, managed code may provide some protection. For example, <code>java.io.FilePermission</code> in the Java <code>SecurityManager</code> allows you to specify restrictions on file operations.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|             | <p>This may not be a feasible solution, and it only limits the impact to the operating system; the rest of your application may still be subject to compromise.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Reference   | <a href="https://owasp.org/www-community/attacks/Path_Traversal">https://owasp.org/www-community/attacks/Path_Traversal</a><br><a href="https://cwe.mitre.org/data/definitions/22.html">https://cwe.mitre.org/data/definitions/22.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| CWE Id      | <a href="https://cwe.mitre.org/data/definitions/22.html">22</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| WASC Id     | 33                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Plugin Id   | <a href="#">6</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| <b>High</b> | <b>SQL Injection</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Description | SQL injection may be possible.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL         | <a href="http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP%27">http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP%27</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Node Name  | http://testasp.vulnweb.com/Search.asp (tfSearch)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Attack     | ZAP'                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidence   | HTTP/1.1 500 Internal Server Error                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL        | <a href="http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3">http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Node Name  | http://testasp.vulnweb.com/Login.asp (RetURL)(tfUName,tfUPass)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Method     | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Attack     | '                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Evidence   | HTTP/1.1 500 Internal Server Error                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL        | <a href="http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3">http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Node Name  | http://testasp.vulnweb.com/Login.asp (RetURL)(tfUName,tfUPass)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Method     | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Attack     | '                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Evidence   | HTTP/1.1 500 Internal Server Error                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL        | <a href="http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F">http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Node Name  | http://testasp.vulnweb.com/Register.asp (RetURL)(tfEmail,tfRName,tfUName,tfUPass)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Method     | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Attack     | '                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Evidence   | HTTP/1.1 500 Internal Server Error                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Instances  | 4                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Solution   | <p>Do not trust client side input, even if there is client side validation in place.</p> <p>In general, type check all data on the server side.</p> <p>If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?'</p> <p>If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries.</p> <p>If database Stored Procedures can be used, use them.</p> <p>Do <i>*not*</i> concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality!</p> <p>Do not create dynamic SQL queries using simple string concatenation.</p> <p>Escape all data received from the client.</p> |

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|           | <p>Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input.</p> <p>Apply the principle of least privilege by using the least privileged database user possible.</p> <p>In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.</p> <p>Grant the minimum database access that is necessary for the application.</p> |
| Reference | <a href="https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html">https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html</a>                                                                                                                                                                                                                                            |
| CWE Id    | <a href="#">89</a>                                                                                                                                                                                                                                                                                                                                                                                                                         |
| WASC Id   | 19                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Plugin Id | <a href="#">40018</a>                                                                                                                                                                                                                                                                                                                                                                                                                      |

|             |                                                                                                                                                                                                                                                                    |
|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>High</b> | <b>SQL Injection - MsSQL (Time Based)</b>                                                                                                                                                                                                                          |
| Description | SQL injection may be possible.                                                                                                                                                                                                                                     |
| URL         | <a href="http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3">http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3</a>                                                                                                    |
| Node Name   | http://testasp.vulnweb.com/Login.asp (RetURL)(tfUName,tfUPass)                                                                                                                                                                                                     |
| Method      | POST                                                                                                                                                                                                                                                               |
| Attack      | ZAP) ' WAITFOR DELAY '0:0:15' --                                                                                                                                                                                                                                   |
| Evidence    |                                                                                                                                                                                                                                                                    |
| Other Info  | The query time is controllable using parameter value [ZAP) ' WAITFOR DELAY '0:0:15' -- ], which caused the request to take [15,220] milliseconds, when the original unmodified query with value [ZAP] took [0] milliseconds.                                       |
| URL         | <a href="http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3">http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3</a>                                                                                                    |
| Node Name   | http://testasp.vulnweb.com/Login.asp (RetURL)(tfUName,tfUPass)                                                                                                                                                                                                     |
| Method      | POST                                                                                                                                                                                                                                                               |
| Attack      | ZAP' WAITFOR DELAY '0:0:15' --                                                                                                                                                                                                                                     |
| Evidence    |                                                                                                                                                                                                                                                                    |
| Other Info  | The query time is controllable using parameter value [ZAP' WAITFOR DELAY '0:0:15' -- ], which caused the request to take [15,215] milliseconds, when the original unmodified query with value [ZAP] took [0] milliseconds.                                         |
| URL         | <a href="http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F">http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F</a>                                                                                                                |
| Node Name   | http://testasp.vulnweb.com/Register.asp (RetURL)(tfEmail,tfRName,tfUName,tfUPass)                                                                                                                                                                                  |
| Method      | POST                                                                                                                                                                                                                                                               |
| Attack      | ZAP) ' WAITFOR DELAY '0:0:15' --                                                                                                                                                                                                                                   |
| Evidence    |                                                                                                                                                                                                                                                                    |
| Other Info  | The query time is controllable using parameter value [ZAP) ' WAITFOR DELAY '0:0:15' -- ], which caused the request to take [15,223] milliseconds, when the original unmodified query with value [ZAP] took [0] milliseconds.                                       |
| Instances   | 3                                                                                                                                                                                                                                                                  |
|             | <p>Do not trust client side input, even if there is client side validation in place.</p> <p>In general, type check all data on the server side.</p> <p>If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?'</p> |

|          |                                                                                                                                                                                                 |
|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Solution | If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries.                                                                                       |
|          | If database Stored Procedures can be used, use them.                                                                                                                                            |
|          | Do <i>*not*</i> concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality!                                                         |
|          | Do not create dynamic SQL queries using simple string concatenation.                                                                                                                            |
|          | Escape all data received from the client.                                                                                                                                                       |
|          | Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input.                                                                                           |
|          | Apply the principle of least privilege by using the least privileged database user possible.                                                                                                    |
|          | In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.                                                              |
|          | Grant the minimum database access that is necessary for the application.                                                                                                                        |
|          | <a href="https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html">https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html</a> |
|          | CWE Id                                                                                                                                                                                          |
|          | WASC Id                                                                                                                                                                                         |
|          | Plugin Id                                                                                                                                                                                       |
|          |                                                                                                                                                                                                 |

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Medium      | Absence of Anti-CSRF Tokens                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Description | No Anti-CSRF tokens were found in a HTML submission form.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|             | A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL /form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf. |
|             | CSRF attacks are effective in a number of situations, including:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|             | * The victim has an active session on the target site.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|             | * The victim is authenticated via HTTP auth on the target site.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|             | * The victim is on the same local network as the target site.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|             | CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.                                                                                                                                                                                                                                                        |
| URL         | <a href="http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault%2Easp%3E">http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault%2Easp%3E</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Node Name   | http://testasp.vulnweb.com/Login.asp (RetURL)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence    | <form action="" method="POST">                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info  | No known Anti-CSRF token [anticsrf, CSRFTOKEN, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the                                                                                                                                                                                                                                                                                                                                                                                                                                                    |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|            | following HTML form: [Form 1: "tfUName" "tfUPass" ].                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL        | <a href="http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F">http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Node Name  | http://testasp.vulnweb.com/Register.asp (RetURL)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Evidence   | <form action="" method="post" enctype="application/x-www-form-urlencoded" name="frmRegister">                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Other Info | No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "tfEmail" "tfRName" "tfUName" "tfUPass" ].                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| URL        | <a href="http://testasp.vulnweb.com/showthread.asp?id=3">http://testasp.vulnweb.com/showthread.asp?id=3</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Node Name  | http://testasp.vulnweb.com/showthread.asp (id)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Evidence   | <form name="frmPostMessage" method="post" enctype="application/x-www-form-urlencoded">                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Other Info | No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "tfSubject" ].                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Instances  | 3                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Solution   | <p>Phase: Architecture and Design</p> <p>Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid.</p> <p>For example, use anti-CSRF packages such as the OWASP CSRFGuard.</p> <p>Phase: Implementation</p> <p>Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script.</p> <p>Phase: Architecture and Design</p> <p>Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330).</p> <p>Note that this can be bypassed using XSS.</p> <p>Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation.</p> <p>Note that this can be bypassed using XSS.</p> <p>Use the ESAPI Session Management control.</p> <p>This control includes a component for CSRF.</p> <p>Do not use the GET method for any request that triggers a state change.</p> <p>Phase: Implementation</p> |

|           |                                                                                                                                                                                                                                                                                                                                            |
|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|           | Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.                                                                                                                       |
| Reference | <a href="https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html">https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html</a><br><a href="https://cwe.mitre.org/data/definitions/352.html">https://cwe.mitre.org/data/definitions/352.html</a> |
| CWE Id    | <a href="#">352</a>                                                                                                                                                                                                                                                                                                                        |
| WASC Id   | 9                                                                                                                                                                                                                                                                                                                                          |
| Plugin Id | <a href="#">10202</a>                                                                                                                                                                                                                                                                                                                      |

| Medium      | Content Security Policy (CSP) Header Not Set                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. |
| URL         | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Node Name   | http://testasp.vulnweb.com                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other Info  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| URL         | <a href="http://testasp.vulnweb.com/Default.asp">http://testasp.vulnweb.com/Default.asp</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Node Name   | http://testasp.vulnweb.com/Default.asp                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other Info  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| URL         | <a href="http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault%2Easp%3F">http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault%2Easp%3F</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Node Name   | http://testasp.vulnweb.com/Login.asp (RetURL)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other Info  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| URL         | <a href="http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F">http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Node Name   | http://testasp.vulnweb.com/Register.asp (RetURL)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Info       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| URL        | <a href="http://testasp.vulnweb.com/Templatize.asp?item=html/about.html">http://testasp.vulnweb.com/Templatize.asp?item=html/about.html</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Node Name  | http://testasp.vulnweb.com/Templatize.asp (item)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Solution   | Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Reference  | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP">https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP</a><br><a href="https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html">https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html</a><br><a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://w3c.github.io/webappsec-csp/">https://w3c.github.io/webappsec-csp/</a><br><a href="https://web.dev/articles/csp">https://web.dev/articles/csp</a><br><a href="https://caniuse.com/#feat=contentsecuritypolicy">https://caniuse.com/#feat=contentsecuritypolicy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a> |
| CWE Id     | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Plugin Id  | <a href="#">10038</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |

|               |                                                                                                                                                                                                                                                                        |
|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Medium</b> | <b>HTTP Only Site</b>                                                                                                                                                                                                                                                  |
| Description   | The site is only served under HTTP and not HTTPS.                                                                                                                                                                                                                      |
| URL           | <a href="http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3">http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3</a>                                                                                                        |
| Node Name     | https://testasp.vulnweb.com/Login.asp ()(tfUName,tfUPass)                                                                                                                                                                                                              |
| Method        | POST                                                                                                                                                                                                                                                                   |
| Attack        |                                                                                                                                                                                                                                                                        |
| Evidence      |                                                                                                                                                                                                                                                                        |
| Other Info    | Failed to connect. ZAP attempted to connect via: https://testasp.vulnweb.com/Login.asp                                                                                                                                                                                 |
| Instances     | 1                                                                                                                                                                                                                                                                      |
| Solution      | Configure your web or application server to use SSL (https).                                                                                                                                                                                                           |
| Reference     | <a href="https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html">https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html</a><br><a href="https://letsencrypt.org/">https://letsencrypt.org/</a> |
| CWE Id        | <a href="#">311</a>                                                                                                                                                                                                                                                    |
| WASC Id       | 4                                                                                                                                                                                                                                                                      |
| Plugin Id     | <a href="#">10106</a>                                                                                                                                                                                                                                                  |

|               |                                                                                                                                                                     |
|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Medium</b> | <b>Missing Anti-clickjacking Header</b>                                                                                                                             |
| Description   | The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options. |
| URL           | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a>                                                                                                 |
| Node Name     | http://testasp.vulnweb.com                                                                                                                                          |
|               |                                                                                                                                                                     |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| URL        | <a href="http://testasp.vulnweb.com/Default.asp">http://testasp.vulnweb.com/Default.asp</a>                                                                                                                                                                                                                                                                                                                                                                                            |
| Node Name  | http://testasp.vulnweb.com/Default.asp                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| URL        | <a href="http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault%2Easp%3F">http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault%2Easp%3F</a>                                                                                                                                                                                                                                                                                                                                          |
| Node Name  | http://testasp.vulnweb.com/Login.asp (RetURL)                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| URL        | <a href="http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F">http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F</a>                                                                                                                                                                                                                                                                                                                                    |
| Node Name  | http://testasp.vulnweb.com/Register.asp (RetURL)                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| URL        | <a href="http://testasp.vulnweb.com/Templatize.asp?item=html/about.html">http://testasp.vulnweb.com/Templatize.asp?item=html/about.html</a>                                                                                                                                                                                                                                                                                                                                            |
| Node Name  | http://testasp.vulnweb.com/Templatize.asp (item)                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Solution   | <p>Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.</p> <p>If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.</p> |
| Reference  | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options</a>                                                                                                                                                                                                                                                                                                  |
| CWE Id     | <a href="#">1021</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |

|             |                                                                                                                                                                                                                                                                                                                                             |
|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| WASC Id     | 15                                                                                                                                                                                                                                                                                                                                          |
| Plugin Id   | <a href="#">10020</a>                                                                                                                                                                                                                                                                                                                       |
| <b>Low</b>  | <b>Application Error Disclosure</b>                                                                                                                                                                                                                                                                                                         |
| Description | This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page. |
| URL         | <a href="http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP%27">http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP%27</a>                                                                                                                                                                                                                   |
| Node Name   | http://testasp.vulnweb.com/Search.asp (tfSearch)                                                                                                                                                                                                                                                                                            |
| Method      | GET                                                                                                                                                                                                                                                                                                                                         |
| Attack      |                                                                                                                                                                                                                                                                                                                                             |
| Evidence    | HTTP/1.1 500 Internal Server Error                                                                                                                                                                                                                                                                                                          |
| Other Info  |                                                                                                                                                                                                                                                                                                                                             |
| URL         | <a href="http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3">http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3</a>                                                                                                                                                                             |
| Node Name   | http://testasp.vulnweb.com/Login.asp (RetURL)(tfUName,tfUPass)                                                                                                                                                                                                                                                                              |
| Method      | POST                                                                                                                                                                                                                                                                                                                                        |
| Attack      |                                                                                                                                                                                                                                                                                                                                             |
| Evidence    | HTTP/1.1 500 Internal Server Error                                                                                                                                                                                                                                                                                                          |
| Other Info  |                                                                                                                                                                                                                                                                                                                                             |
| URL         | <a href="http://testasp.vulnweb.com/Register.asp?RetURL=%2FTemplatize%2Easp%3Fitem%3Dhtml%2Fabout%2Ehtml">http://testasp.vulnweb.com/Register.asp?RetURL=%2FTemplatize%2Easp%3Fitem%3Dhtml%2Fabout%2Ehtml</a>                                                                                                                               |
| Node Name   | http://testasp.vulnweb.com/Register.asp (RetURL)(tfEmail,tfRName,tfUName,tfUPass)                                                                                                                                                                                                                                                           |
| Method      | POST                                                                                                                                                                                                                                                                                                                                        |
| Attack      |                                                                                                                                                                                                                                                                                                                                             |
| Evidence    | HTTP/1.1 500 Internal Server Error                                                                                                                                                                                                                                                                                                          |
| Other Info  |                                                                                                                                                                                                                                                                                                                                             |
| Instances   | 3                                                                                                                                                                                                                                                                                                                                           |
| Solution    | Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.                                                                                 |
| Reference   |                                                                                                                                                                                                                                                                                                                                             |
| CWE Id      | <a href="#">550</a>                                                                                                                                                                                                                                                                                                                         |
| WASC Id     | 13                                                                                                                                                                                                                                                                                                                                          |
| Plugin Id   | <a href="#">90022</a>                                                                                                                                                                                                                                                                                                                       |

|             |                                                                                                                                                                                                                                                                                                          |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>Cookie No HttpOnly Flag</b>                                                                                                                                                                                                                                                                           |
| Description | A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible. |
| URL         | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a>                                                                                                                                                                                                                                      |
| Node        |                                                                                                                                                                                                                                                                                                          |

|            |                                                                                                 |
|------------|-------------------------------------------------------------------------------------------------|
| Name       | http://testasp.vulnweb.com                                                                      |
| Method     | GET                                                                                             |
| Attack     |                                                                                                 |
| Evidence   | Set-Cookie: ASPSESSIONIDCQDADSDD                                                                |
| Other Info |                                                                                                 |
| Instances  | 1                                                                                               |
| Solution   | Ensure that the HttpOnly flag is set for all cookies.                                           |
| Reference  | <a href="https://owasp.org/www-community/HttpOnly">https://owasp.org/www-community/HttpOnly</a> |
| CWE Id     | <a href="#">1004</a>                                                                            |
| WASC Id    | 13                                                                                              |
| Plugin Id  | <a href="#">10010</a>                                                                           |

|             |                                                                                                                                                                                                                                                                             |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>Cookie without SameSite Attribute</b>                                                                                                                                                                                                                                    |
| Description | A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks. |
| URL         | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a>                                                                                                                                                                                                         |
| Node Name   | http://testasp.vulnweb.com                                                                                                                                                                                                                                                  |
| Method      | GET                                                                                                                                                                                                                                                                         |
| Attack      |                                                                                                                                                                                                                                                                             |
| Evidence    | Set-Cookie: ASPSESSIONIDCQDADSDD                                                                                                                                                                                                                                            |
| Other Info  |                                                                                                                                                                                                                                                                             |
| Instances   | 1                                                                                                                                                                                                                                                                           |
| Solution    | Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.                                                                                                                                                                              |
| Reference   | <a href="https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site">https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site</a>                                                                                                           |
| CWE Id      | <a href="#">1275</a>                                                                                                                                                                                                                                                        |
| WASC Id     | 13                                                                                                                                                                                                                                                                          |
| Plugin Id   | <a href="#">10054</a>                                                                                                                                                                                                                                                       |

|             |                                                                                                                                                                                            |
|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>Information Disclosure - Debug Error Messages</b>                                                                                                                                       |
| Description | The response appeared to contain common error messages returned by platforms such as ASP.NET, and Web-servers such as IIS and Apache. You can configure the list of common debug messages. |
| URL         | <a href="http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP%27">http://testasp.vulnweb.com/Search.asp?tfSearch=ZAP%27</a>                                                                  |
| Node Name   | http://testasp.vulnweb.com/Search.asp (tfSearch)                                                                                                                                           |
| Method      | GET                                                                                                                                                                                        |
| Attack      |                                                                                                                                                                                            |
| Evidence    | Internal server error                                                                                                                                                                      |
| Other Info  |                                                                                                                                                                                            |
| URL         | <a href="http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3">http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowthread%2Easp%3Fid%3D3</a>                            |
| Node Name   | http://testasp.vulnweb.com/Login.asp (RetURL)(tfUName,tfUPass)                                                                                                                             |

|            |                                                                                                                                                                                                               |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Method     | POST                                                                                                                                                                                                          |
| Attack     |                                                                                                                                                                                                               |
| Evidence   | Internal server error                                                                                                                                                                                         |
| Other Info |                                                                                                                                                                                                               |
| URL        | <a href="http://testasp.vulnweb.com/Register.asp?RetURL=%2FTemplatize%2Easp%3Fitem%3Dhtml%2Fabout%2Ehtml">http://testasp.vulnweb.com/Register.asp?RetURL=%2FTemplatize%2Easp%3Fitem%3Dhtml%2Fabout%2Ehtml</a> |
| Node Name  | http://testasp.vulnweb.com/Register.asp (RetURL)(tfEmail,tfRName,tfUName,tfUPass)                                                                                                                             |
| Method     | POST                                                                                                                                                                                                          |
| Attack     |                                                                                                                                                                                                               |
| Evidence   | Internal server error                                                                                                                                                                                         |
| Other Info |                                                                                                                                                                                                               |
| Instances  | 3                                                                                                                                                                                                             |
| Solution   | Disable debugging messages before pushing to production.                                                                                                                                                      |
| Reference  |                                                                                                                                                                                                               |
| CWE Id     | <a href="#">1295</a>                                                                                                                                                                                          |
| WASC Id    | 13                                                                                                                                                                                                            |
| Plugin Id  | <a href="#">10023</a>                                                                                                                                                                                         |

|             |                                                                                                                                                                                                                                                                                                     |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)</b>                                                                                                                                                                                                                    |
| Description | The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to. |
| URL         | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a>                                                                                                                                                                                                                                 |
| Node Name   | http://testasp.vulnweb.com                                                                                                                                                                                                                                                                          |
| Method      | GET                                                                                                                                                                                                                                                                                                 |
| Attack      |                                                                                                                                                                                                                                                                                                     |
| Evidence    | X-Powered-By: ASP.NET                                                                                                                                                                                                                                                                               |
| Other Info  |                                                                                                                                                                                                                                                                                                     |
| URL         | <a href="http://testasp.vulnweb.com/Default.asp">http://testasp.vulnweb.com/Default.asp</a>                                                                                                                                                                                                         |
| Node Name   | http://testasp.vulnweb.com/Default.asp                                                                                                                                                                                                                                                              |
| Method      | GET                                                                                                                                                                                                                                                                                                 |
| Attack      |                                                                                                                                                                                                                                                                                                     |
| Evidence    | X-Powered-By: ASP.NET                                                                                                                                                                                                                                                                               |
| Other Info  |                                                                                                                                                                                                                                                                                                     |
| URL         | <a href="http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F">http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F</a>                                                                                                                                                 |
| Node Name   | http://testasp.vulnweb.com/Register.asp (RetURL)                                                                                                                                                                                                                                                    |
| Method      | GET                                                                                                                                                                                                                                                                                                 |
| Attack      |                                                                                                                                                                                                                                                                                                     |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | X-Powered-By: ASP.NET                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| URL        | <a href="http://testasp.vulnweb.com/Templatize.asp?item=html/about.html">http://testasp.vulnweb.com/Templatize.asp?item=html/about.html</a>                                                                                                                                                                                                                                                                                                                                                    |
| Node Name  | http://testasp.vulnweb.com/Templatize.asp (item)                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Evidence   | X-Powered-By: ASP.NET                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| URL        | <a href="http://testasp.vulnweb.com/robots.txt">http://testasp.vulnweb.com/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                      |
| Node Name  | http://testasp.vulnweb.com/robots.txt                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Evidence   | X-Powered-By: ASP.NET                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Solution   | Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.                                                                                                                                                                                                                                                                                                                                                                         |
| Reference  | <a href="https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework">https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework</a><br><a href="https://www.troyhunt.com/shhh-dont-let-your-response-headers/">https://www.troyhunt.com/shhh-dont-let-your-response-headers/</a> |
| CWE Id     | <a href="#">497</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| WASC Id    | 13                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Plugin Id  | <a href="#">10037</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |

|             |                                                                                                                                                                                                                                   |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>Server Leaks Version Information via "Server" HTTP Response Header Field</b>                                                                                                                                                   |
| Description | The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to. |
| URL         | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a>                                                                                                                                                               |
| Node Name   | http://testasp.vulnweb.com                                                                                                                                                                                                        |
| Method      | GET                                                                                                                                                                                                                               |
| Attack      |                                                                                                                                                                                                                                   |
| Evidence    | Microsoft-IIS/8.5                                                                                                                                                                                                                 |
| Other Info  |                                                                                                                                                                                                                                   |
| URL         | <a href="http://testasp.vulnweb.com/Default.asp">http://testasp.vulnweb.com/Default.asp</a>                                                                                                                                       |
| Node Name   | http://testasp.vulnweb.com/Default.asp                                                                                                                                                                                            |
| Method      | GET                                                                                                                                                                                                                               |
| Attack      |                                                                                                                                                                                                                                   |
|             |                                                                                                                                                                                                                                   |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | Microsoft-IIS/8.5                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| URL        | <a href="http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F">http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F</a>                                                                                                                                                                                                                                                                                                                             |
| Node Name  | http://testasp.vulnweb.com/Register.asp (RetURL)                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Evidence   | Microsoft-IIS/8.5                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| URL        | <a href="http://testasp.vulnweb.com/Templatize.asp?item=html/about.html">http://testasp.vulnweb.com/Templatize.asp?item=html/about.html</a>                                                                                                                                                                                                                                                                                                                                     |
| Node Name  | http://testasp.vulnweb.com/Templatize.asp (item)                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Evidence   | Microsoft-IIS/8.5                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| URL        | <a href="http://testasp.vulnweb.com/robots.txt">http://testasp.vulnweb.com/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                       |
| Node Name  | http://testasp.vulnweb.com/robots.txt                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Evidence   | Microsoft-IIS/8.5                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Solution   | Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.                                                                                                                                                                                                                                                                                                                                  |
| Reference  | <a href="https://httpd.apache.org/docs/current/mod/core.html#servertokens">https://httpd.apache.org/docs/current/mod/core.html#servertokens</a><br><a href="https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)">https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)</a><br><a href="https://www.troyhunt.com/shhh-dont-let-your-response-headers/">https://www.troyhunt.com/shhh-dont-let-your-response-headers/</a> |
| CWE Id     | <a href="#">497</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| WASC Id    | 13                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Plugin Id  | <a href="#">10036</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                           |

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>X-Content-Type-Options Header Missing</b>                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Description | The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing. |
| URL         | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a>                                                                                                                                                                                                                                                                                                                                                                                                  |
| Node Name   | http://testasp.vulnweb.com                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |

|            |                                                                                                                                                                                                                                                                                                                              |
|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Attack     |                                                                                                                                                                                                                                                                                                                              |
| Evidence   |                                                                                                                                                                                                                                                                                                                              |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. |
| URL        | <a href="http://testasp.vulnweb.com/Default.asp">http://testasp.vulnweb.com/Default.asp</a>                                                                                                                                                                                                                                  |
| Node Name  | http://testasp.vulnweb.com/Default.asp                                                                                                                                                                                                                                                                                       |
| Method     | GET                                                                                                                                                                                                                                                                                                                          |
| Attack     |                                                                                                                                                                                                                                                                                                                              |
| Evidence   |                                                                                                                                                                                                                                                                                                                              |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. |
| URL        | <a href="http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F">http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F</a>                                                                                                                                                                          |
| Node Name  | http://testasp.vulnweb.com/Register.asp (RetURL)                                                                                                                                                                                                                                                                             |
| Method     | GET                                                                                                                                                                                                                                                                                                                          |
| Attack     |                                                                                                                                                                                                                                                                                                                              |
| Evidence   |                                                                                                                                                                                                                                                                                                                              |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. |
| URL        | <a href="http://testasp.vulnweb.com/Templatize.asp?item=html/about.html">http://testasp.vulnweb.com/Templatize.asp?item=html/about.html</a>                                                                                                                                                                                  |
| Node Name  | http://testasp.vulnweb.com/Templatize.asp (item)                                                                                                                                                                                                                                                                             |
| Method     | GET                                                                                                                                                                                                                                                                                                                          |
| Attack     |                                                                                                                                                                                                                                                                                                                              |
| Evidence   |                                                                                                                                                                                                                                                                                                                              |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. |
| URL        | <a href="http://testasp.vulnweb.com/robots.txt">http://testasp.vulnweb.com/robots.txt</a>                                                                                                                                                                                                                                    |
| Node Name  | http://testasp.vulnweb.com/robots.txt                                                                                                                                                                                                                                                                                        |
| Method     | GET                                                                                                                                                                                                                                                                                                                          |
| Attack     |                                                                                                                                                                                                                                                                                                                              |
| Evidence   |                                                                                                                                                                                                                                                                                                                              |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses. |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                     |
|            | Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.                                                                                                                                                        |

|           |                                                                                                                                                                                                                                                                                                                                                                                        |
|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Solution  | If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.                                                                                                                                                           |
| Reference | <a href="https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)">https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)</a><br><a href="https://owasp.org/www-community/Security-Headers">https://owasp.org/www-community/Security-Headers</a> |
| CWE Id    | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                    |
| WASC Id   | 15                                                                                                                                                                                                                                                                                                                                                                                     |
| Plugin Id | <a href="#">10021</a>                                                                                                                                                                                                                                                                                                                                                                  |

| Informational | GET for POST                                                                                                                                                                                                                                                                                                                                                              |
|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | A request that was originally observed as a POST was also accepted as a GET. This issue does not represent a security weakness unto itself, however, it may facilitate simplification of other attacks. For example if the original POST is subject to Cross-Site Scripting (XSS), then this finding may indicate that a simplified (GET based) XSS may also be possible. |
| URL           | <a href="http://testasp.vulnweb.com/showthread.asp?id=3">http://testasp.vulnweb.com/showthread.asp?id=3</a>                                                                                                                                                                                                                                                               |
| Node Name     | http://testasp.vulnweb.com/showthread.asp (tfSubject,tfText)                                                                                                                                                                                                                                                                                                              |
| Method        | GET                                                                                                                                                                                                                                                                                                                                                                       |
| Attack        |                                                                                                                                                                                                                                                                                                                                                                           |
| Evidence      | GET http://testasp.vulnweb.com/showthread.asp?tfSubject=ZAP&tfText= HTTP/1.1                                                                                                                                                                                                                                                                                              |
| Other Info    |                                                                                                                                                                                                                                                                                                                                                                           |
| Instances     | 1                                                                                                                                                                                                                                                                                                                                                                         |
| Solution      | Ensure that only POST is accepted where POST is expected.                                                                                                                                                                                                                                                                                                                 |
| Reference     |                                                                                                                                                                                                                                                                                                                                                                           |
| CWE Id        | <a href="#">16</a>                                                                                                                                                                                                                                                                                                                                                        |
| WASC Id       | 20                                                                                                                                                                                                                                                                                                                                                                        |
| Plugin Id     | <a href="#">10058</a>                                                                                                                                                                                                                                                                                                                                                     |

| Informational | Information Disclosure - Suspicious Comments                                                                                                                                                                                                                            |
|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The response appears to contain suspicious comments which may help an attacker.                                                                                                                                                                                         |
| URL           | <a href="http://testasp.vulnweb.com/jscripsts/tiny_mce/tiny_mce.js">http://testasp.vulnweb.com/jscripsts/tiny_mce/tiny_mce.js</a>                                                                                                                                       |
| Node Name     | http://testasp.vulnweb.com/jscripsts/tiny_mce/tiny_mce.js                                                                                                                                                                                                               |
| Method        | GET                                                                                                                                                                                                                                                                     |
| Attack        |                                                                                                                                                                                                                                                                         |
| Evidence      | query                                                                                                                                                                                                                                                                   |
| Other Info    | The following pattern was used: \bQUERY\b and was detected in likely comment: "/"==1&&tinyMCE.baseURL.charAt(0)!="/"){tinyMCE.baseURL=this.documentBasePath+"/"+tinyMCE.baseURL;}this.defParam("mode","none","", see evidence field for the suspicious comment/snippet. |
| Instances     | 1                                                                                                                                                                                                                                                                       |
| Solution      | Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.                                                                                                                                                    |
| Reference     |                                                                                                                                                                                                                                                                         |
| CWE Id        | <a href="#">615</a>                                                                                                                                                                                                                                                     |
| WASC Id       | 13                                                                                                                                                                                                                                                                      |
| Plugin Id     | <a href="#">10027</a>                                                                                                                                                                                                                                                   |

| Informational | Session Management Response Identified                                                                                                                                                                                                                                                                                                                                            |
|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified. |
| URL           | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a>                                                                                                                                                                                                                                                                                                               |
| Node Name     | http://testasp.vulnweb.com                                                                                                                                                                                                                                                                                                                                                        |
| Method        | GET                                                                                                                                                                                                                                                                                                                                                                               |
| Attack        |                                                                                                                                                                                                                                                                                                                                                                                   |
| Evidence      | ASPSESSIONIDCQDADSDD                                                                                                                                                                                                                                                                                                                                                              |
| Other Info    | cookie:ASPSESSIONIDCQDADSDD                                                                                                                                                                                                                                                                                                                                                       |
| Instances     | 1                                                                                                                                                                                                                                                                                                                                                                                 |
| Solution      | This is an informational alert rather than a vulnerability and so there is nothing to fix.                                                                                                                                                                                                                                                                                        |
| Reference     | <a href="https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/">https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/</a>                                                                                                                                                                                               |
| CWE Id        |                                                                                                                                                                                                                                                                                                                                                                                   |
| WASC Id       |                                                                                                                                                                                                                                                                                                                                                                                   |
| Plugin Id     | <a href="#">10112</a>                                                                                                                                                                                                                                                                                                                                                             |

| Informational | User Agent Fuzzer                                                                                                                                                                                                      |
|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response. |
| URL           | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a>                                                                                                                                                    |
| Node Name     | http://testasp.vulnweb.com                                                                                                                                                                                             |
| Method        | GET                                                                                                                                                                                                                    |
| Attack        | Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)                                                                                                                                                                     |
| Evidence      |                                                                                                                                                                                                                        |
| Other Info    |                                                                                                                                                                                                                        |
| URL           | <a href="http://testasp.vulnweb.com">http://testasp.vulnweb.com</a>                                                                                                                                                    |
| Node Name     | http://testasp.vulnweb.com                                                                                                                                                                                             |
| Method        | GET                                                                                                                                                                                                                    |
| Attack        | Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)                                                                                                                                                                     |
| Evidence      |                                                                                                                                                                                                                        |
| Other Info    |                                                                                                                                                                                                                        |
| URL           | <a href="http://testasp.vulnweb.com/Default.asp">http://testasp.vulnweb.com/Default.asp</a>                                                                                                                            |
| Node Name     | http://testasp.vulnweb.com/Default.asp                                                                                                                                                                                 |
| Method        | GET                                                                                                                                                                                                                    |
| Attack        | Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)                                                                                                                                                                     |
| Evidence      |                                                                                                                                                                                                                        |

|            |                                                                                                                                                     |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Other Info |                                                                                                                                                     |
| URL        | <a href="http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F">http://testasp.vulnweb.com/Register.asp?RetURL=%2FDefault%2Easp%3F</a> |
| Node Name  | http://testasp.vulnweb.com/Register.asp (RetURL)(tfEmail,tfRName,tfUName,tfUPass)                                                                   |
| Method     | POST                                                                                                                                                |
| Attack     | Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)                                                                                                  |
| Evidence   |                                                                                                                                                     |
| Other Info |                                                                                                                                                     |
| URL        | <a href="http://testasp.vulnweb.com/showthread.asp?id=3">http://testasp.vulnweb.com/showthread.asp?id=3</a>                                         |
| Node Name  | http://testasp.vulnweb.com/showthread.asp (id)(tfSubject,tfText)                                                                                    |
| Method     | POST                                                                                                                                                |
| Attack     | Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)                                                                                                  |
| Evidence   |                                                                                                                                                     |
| Other Info |                                                                                                                                                     |
| Instances  | Systemic                                                                                                                                            |
| Solution   |                                                                                                                                                     |
| Reference  | <a href="https://owasp.org/wstg">https://owasp.org/wstg</a>                                                                                         |
| CWE Id     |                                                                                                                                                     |
| WASC Id    |                                                                                                                                                     |
| Plugin Id  | <a href="#">10104</a>                                                                                                                               |